

Aviral Srivastava

Security Researcher | AI/ML Infrastructure Security | Vulnerability Research | Offensive Security

+1 814 769 6414 aviralyash27@gmail.com aviralsrivastava.tech
linkedin.com/in/aviralsrivastava23 github.com/Aviral2642 [Speaker Profile](#)

Recognition

Pwnie Awards 2026 Nominee, Best Server-Side / Cloud Bug. *The highest honor in offensive security research, presented at DEF CON and known as the Oscars of cybersecurity. Nominees are chosen worldwide by past winners.*

CVE-2026-33017 added to the **CISA Known Exploited Vulnerabilities catalog**, exploited 20 hours after disclosure, before any public proof of concept existed.

First AI-security framework mapping accepted into the **NIST OLIR catalog**. Listed Point of Contact on NIST CSRC.

RSA Security Scholar 2025. Invitation-only; RSA Conference invites roughly 40 top cybersecurity programs, each nominating one student.

Vulnerability Research and Coordinated Disclosure

CVE-2026-33017 | **Langflow** | Unauthenticated remote code execution via public flow endpoint | *CVSS 9.3 Critical, KEV, [writeup](#)*

CVE-2026-69258 | **Flowise** | Unauthenticated property injection into flow execution context | *CVSS 8.8 High, [writeup](#)*

CVE-2026-73081 | **Activepieces** | Command injection to RCE in the worker compilation pipeline, before any sandbox is created | *CVSS 8.7 High, co-reported, [writeup](#)*

CVE-2026-73083 | **Activepieces** | V8 isolate sandbox bypass via **importFresh** module loading, executing user code in the host engine process | *CVSS 7.6 High, co-reported, [writeup](#)*

CVE-2026-73084 | **Activepieces** | Reflected cross-site scripting in the OAuth redirect endpoint | *CVSS 6.1, sole reporter, [writeup](#)*

CVE-2026-53923 | **vLLM** | Cross-tenant GPU memory disclosure via integer truncation in GGUF dequantization kernels | *CVSS 5.3, CWE-681, [writeup](#)*

CVE-2026-32628 | **AnythingLLM** | SQL injection | *High, [writeup](#)*

Embargoed | **AI agent infrastructure** | OAuth trust-boundary failure and SSRF via unvalidated authorization metadata in a widely deployed agent protocol SDK | *2 Critical, pending vendor fix*

- Two additional Critical-severity authorization bypasses under active vendor coordination in widely deployed identity and access infrastructure, both incomplete-fix findings against prior published advisories.
- **Google Open Source VRP**, accepted and fixed. Two memory safety defects in **sentencepiece**, the tokenizer backbone of Gemma, T5, and PaLM. Authored the upstream fix, merged as [PR #1207](#), closing an incomplete patch for a prior CVE.
- Published an audit of [221 silent integer truncation sites](#) across vLLM's CUDA and C++ surface, documenting the bug class rather than one instance.
- Further disclosures to NVIDIA PSIRT, Hugging Face, Microsoft MSRC, GitHub Security Lab, and Cisco across **safetensors**, **llama.cpp**, **Ollama**, and **ONNX Runtime**.
- **Press**. Named as discoverer of CVE-2026-33017 in **The Hacker News**, **Help Net Security**, **Infosecurity Magazine**, **Sysdig**, and **Qualys ThreatProtect**.

Experience

Amazon

Aug 2025 – Present

Security Engineer (L4), Ads Product Security

Sunnyvale, CA

- Lead application security reviews across advertising platforms via source code analysis, threat modeling, and penetration testing, partnering with engineering on remediation before launch.
- Own AI/ML security assessment for customer-facing products across prompt injection, cross-tenant data leakage, agentic workflow abuse, and RAG hardening.

- Built an automated threat modeling tool that cut assessment turnaround from days to hours. Adopted org-wide by the security engineering team.

Standards Body Contributions

- **NIST Online Informative References Catalog.** Mapped OWASP LLM Top 10 v2.0 to NIST CSF 2.0 across 169 relationship entries covering 77 of 106 subcategories. Published April 2026, the first AI-security mapping the catalog has accepted.
- **MITRE CWE and CAPEC.** Three accepted submissions in Phase 3 analyst review: weakness classes for executable logic isolation in AI workflow definitions and silent tensor metadata truncation in ML inference engines, plus a matching attack pattern.
- **NIST SP 1347.** Formal public comment on the CSF Informative References Quick-Start Guide, addressing AI/ML reference gaps.

Invited Talks

- **BSides Las Vegas 2026**, Breaking Ground. *Rejected-Input Programming: Exploiting Parsers That Say No Too Late.*
- **RSA Conference 2026.** *From Prompt to Pager: Preparing for AI-Native Incidents Now.* **ISACA North America 2026.** *Breaking the Loop: Offensive Testing of RL and Agentic AI Systems.*
- **CactusCon 13 and 14**, **CypherCon 2025**, **HOPE XV**, **BSides** Salt Lake City, Twin Cities, Chicago, Bangalore.

Research, Publications, and Open Source

- **20+ peer-reviewed publications** and **2 granted patents** across ML for threat detection, cryptography, and malware analysis. Poster accepted at the **NeurIPS** Red Teaming GenAI workshop.
- **Co-authored textbooks:** [Machine Learning for Hackers](#) and [Internet of Things](#) (RLK Enterprises, 2023), first author on the latter.
- Peer reviewer for **NeurIPS**, **ACM**, and **IEEE** venues. MS thesis on automated generation of cryptographic CTF challenges using LLMs.
- **Open source tooling.** [KernelGhost](#) (eBPF rootkit framework, hypervisor escape, UEFI implants), [AdversaryPilot](#) (ATLAS-aligned attack planning for LLM and agent systems), [ZeroDayForge](#) (protocol fuzzers, polymorphic shellcode engine).

Education

The Pennsylvania State University, MS Cybersecurity Analytics and Operations, GPA 4.0 May 2025
Amity University, BTech Computer Science Jul 2023

Awards and Credentials

- **Cybersecurity Innovator of the Year**, BSides Bangalore. **Hack The Box:** Pro Hacker, top 200 globally, 24th in the United States.
- **OSCP** (Offensive Security Certified Professional). **CCSK v5** (Cloud Security Alliance).

Technical Skills

Languages: C, C++, Python, x86 Assembly, JavaScript, Bash, SQL

Vulnerability Research: Memory corruption, exploit development, reverse engineering, kernel and hypervisor internals, parser and deserialization security, fuzzing, GPU memory analysis. IDA Pro, Ghidra, radare2, ASAN, libFuzzer

AI/ML Security: LLM and GenAI attack surface, prompt injection, agentic workflow abuse, RAG risk assessment, model file and tokenizer security, inference engine internals

AppSec and Frameworks: Secure SDLC, threat modeling, SAST/DAST, API security. MITRE ATT&CK, ATLAS, NIST CSF 2.0, OWASP LLM Top 10, CWE, CAPEC, CVSS v4